RECUEIL DES BESOINS

Nom du projet	MedImage Trust
Équipe	Amal Ben Khalifa – Nour Ben Abdeljelil – Nourhen Toumi
Dépôt GitHub	Amal-wa/MedImage-Trust

1. Introduction et objectifs

1.1 Objet du document

Ce document formalise les besoins fonctionnels, les exigences de sécurité et les exigences de disponibilité et de résilience de MedImage Trust. Il suit une démarche d'ingénierie des exigences de sécurité (IES/SRE, **Security Requirements Engineering**) : capture, analyse, spécification et gestion des exigences de sécurité. Les besoins fonctionnels et les exigences de sécurité sont séparés, et chaque exigence est associée à un critère de validation mesurable.

1.2 Contexte

Le contexte, la solution, le périmètre et l'architecture de MedImage Trust sont décrits dans le cahier des charges. Pour l'analyse des exigences, trois points comptent : un objet DICOM comprend des pixels, un en-tête et un préambule, tous non fiables à l'entrée ; les marques sont appliquées **à chaque émission**, sur une copie régénérée à partir de l'original archivé ; aucune image diagnostique n'est conservée hors ligne dans la PWA.

1.3 Principes directeurs

- **Shift-Left:** intégrer la sécurité dès la phase de spécification du cycle de développement (SDLC sécurisé).
- **Perspective de l'attaquant** : identifier les abus et les scénarios de menace pour chaque cas d'utilisation.
- **Triade CIA:** préserver la confidentialité, l'intégrité et la disponibilité des actifs critiques.
- **Exigences SMART:** chaque exigence est spécifique, mesurable, exploitable, réaliste et opportune.

2. Acteurs et actifs

2.1 Acteurs et privilèges

Acteur / rôle	Objectifs légitimes	Accès autorisés	Limites / restrictions
Visiteur	Consulter les informations générales.	Pages publiques non sensibles, si elles existent.	Aucun accès aux API métier, aux images, aux comptes ou aux données de santé.
Clinicien	Importer, consulter et transmettre des images dans le parcours clinique ; préparer un export de recherche autorisé.	Images et dossiers de son établissement ; opérations cliniques autorisées.	Pas d'accès aux dossiers hors périmètre ni aux clés.
Spécialiste	Consulter et vérifier les images reçues pour son activité médicale ; importer des images.	Images qui lui sont adressées ; import ; fonction de vérification.	Pas d'accès aux dossiers d'autres destinataires.
Chercheur	Recevoir et exploiter des copies préparées pour la recherche.	Copies de recherche pseudonymisées et données explicitement autorisées.	Aucun accès aux identifiants directs ni à la clé de réidentification.

Acteur / rôle	Objectifs légitimes	Accès autorisés	Limites / restrictions
Responsable sécurité	Examiner les alertes et les journaux ; analyser une copie suspecte.	Journaux d'audit en lecture ; fonction d'analyse de fingerprint.	Ne gère ni les comptes ni les rôles ; accès au contenu médical limité ; analyses journalisées.
Administrateur	Gérer les comptes, les rôles et les paramètres de la plateforme.	Comptes, rôles et paramètres techniques.	Aucun accès aux images ; aucune écriture dans les journaux ; tout changement de privilège est notifié au responsable sécurité (séparation des tâches).
Service / système	Valider, stocker, marquer et vérifier les objets DICOM.	Accès technique strictement nécessaire aux fichiers, métadonnées et secrets.	Identité de service dédiée ; aucun secret en clair dans les journaux ; opérations auditables.

2.2 Actifs à protéger

ID	Actif	Propriétaire	Criticité	Impact en cas d'atteinte
A01	Comptes, identifiants et rôles	Exploitation / établissements	Élevée	Usurpation d'identité, accès indu aux images et opérations non autorisées.
A02	Images DICOM : pixels, en-tête et préambule ; originaux et copies	Établissement émetteur	Élevée	Atteinte à la confidentialité, altération du diagnostic, compromission par fichier malveillant ou perte d'archives.
A03	Données dissimulées : jeton, preuve signée, codes destinataires	Établissement émetteur	Élevée	Divulgation de données cliniques, falsification de provenance ou d'intégrité, fuite non attribuable.
A04	Clés de chiffrement et de signature	Responsable sécurité / exploitation	Élevée	Déchiffrement non autorisé, falsification ou contournement des mécanismes de protection.
A05	Journaux, traces d'accès et d'opérations	Exploitation / sécurité	Moyenne à élevée	Perte de traçabilité et de non-répudiation ; incident non détecté.

3. Besoins fonctionnels

Le système permet aux cliniciens, spécialistes, chercheurs, responsables sécurité et administrateurs, selon leurs rôles, de s'authentifier, d'importer des images DICOM, de transmettre une copie dans un flux clinique ou de recherche, d'extraire le lien patient, de vérifier une image, d'analyser une fuite et d'administrer la plateforme. Chaque besoin fonctionnel BFxx correspond au cas d'utilisation CUxx de même numéro.

Le patient reste une partie prenante, sans compte dans cette version.

ID	Besoin fonctionnel	Acteur	Entrées	Résultat attendu	Priorité
BF01 / CU01	S'authentifier et accéder aux fonctions autorisées	Tous les rôles	Identifiants	Session établie ou refus explicite ; fonctions limitées au rôle.	Must
BF02 / CU02	Importer et archiver une image DICOM	Clinicien, spécialiste	Fichier DICOM	Fichier contrôlé et original archivé, ou rejet motivé.	Must
BF03 / CU03	Transmettre une copie en flux clinique	Clinicien	Image de référence, destinataire	Copie régénérée, marquée et tracée ; ROI préservée.	Must
BF04 / CU04	Préparer un export de recherche	Clinicien habilité (chercheur destinataire)	Image, protocole, laboratoire	En-tête nettoyé ; copie marquée ; jeton conservé seulement si le protocole l'autorise.	Must
BF05 / CU05	Extraire le lien patient (réidentification autorisée)	Clinicien habilité	Copie et autorisation	Lien interprétable uniquement par l'établissement détenteur de la clé.	Must

ID	Besoin fonctionnel	Acteur	Entrées	Résultat attendu	Priorité
BF06 / CU06	Vérifier la ROI et la provenance	Spécialiste, responsable sécurité	Image reçue	Résultat positif ou négatif, avec un motif non sensible.	Must
BF07 / CU07	Individualiser chaque copie émise	Système	Copie, destinataire	Code du destinataire inséré ; émission journalisée.	Must
BF08 / CU08	Analyser une copie suspecte	Responsable sécurité	Copie suspecte, registre des émissions	Rapport d'attribution avec niveau de confiance ; analyse auditée.	Should
BF09 / CU09	Administrer les rôles et les paramètres	Administrateur	Compte, rôle ou paramètre	Modification appliquée, journalisée et notifiée.	Must
BF10 / CU10	Consulter les alertes et les événements	Responsable sécurité	Filtres de recherche	Alertes qualifiées ; aucune modification possible des journaux.	Must

Cas d'utilisation inclus. Lors de CU03 et CU04, le système réalise automatiquement les cas d'utilisation suivants (diagrammes en annexe A) :

ID	Cas d'utilisation inclus	Relation
CU11	Régénérer et marquer la copie à partir de l'original archivé	Inclus par CU03 et CU04
CU12	Insérer le jeton chiffré (stéganographie, partition S)	Extension de CU11 : flux clinique, ou protocole de recherche qui l'autorise
CU13	Signer la ROI et la partition S (watermarking, partition W)	Inclus par CU11
CU07	Insérer le code du destinataire (fingerprinting, partition F)	Inclus par CU11
CU14	Nettoyer l'en-tête DICOM	Inclus par CU04

3.1 Scénarios d'utilisation

ID	Acteur	Préconditions	Scénario nominal	Exceptions / résultat
CU01	Tous les rôles	Compte actif et rôle attribué.	1. Saisir ses identifiants. 2. Le système établit une session. 3. L'acteur accède uniquement aux fonctions de son rôle.	Identifiants invalides : refus et journalisation. Échecs répétés : verrouillage et alerte.
CU02	Clinicien, spécialiste	Session active ; droit d'import.	1. Sélectionner le fichier. 2. Le soumettre. 3. Le système contrôle la structure, le préambule et le contenu. 4. Il archive l'original et délimite la ROI et la RONI.	Fichier invalide, suspect ou trop volumineux : rejet, journalisation, alerte si suspect. RONI insuffisante : image déclarée « non marquable » (RM05).
CU03	Clinicien	Original archivé ; destinataire clinique autorisé.	1. Choisir l'image et le destinataire. 2. Le système vérifie les droits. 3. Il régénère et marque la copie (CU11). 4. Il transmet la copie. 5. Il journalise l'émission.	Droit absent : refus. Marquage en échec : émission annulée. Image non marquable : mode dégradé (RM05).
CU04	Clinicien habilité (chercheur destinataire)	Protocole de recherche autorisé ; original archivé.	1. Choisir l'image, le laboratoire et le protocole. 2. Le système vérifie les droits et le protocole. 3. Il nettoie l'en-tête (CU14). 4. Il régénère et marque la copie (CU11) ; le jeton n'est inséré que si le protocole l'autorise. 5. Il transmet et journalise.	Protocole non autorisé ou image non marquable : export refusé. Identifiant direct résiduel détecté : export bloqué.

ID	Acteur	Préconditions	Scénario nominal	Exceptions / résultat
CU05	Clinicien habilité	Copie contenant un jeton chiffré ; autorisation et clé de l'établissement.	1. Demander l'extraction. 2. Le système vérifie le droit. 3. Il restitue le lien patient dans le périmètre autorisé.	Sans clé ou sans droit : aucune donnée identifiante restituée ; événement signalé.
CU06	Spécialiste, responsable sécurité	Image reçue.	1. Soumettre l'image. 2. Le système vérifie la preuve signée : ROI, coordonnées, partition S, émetteur. 3. Il affiche le résultat.	ROI, coordonnées ou jeton modifiés, ou signature invalide : échec explicite.
CU07	Système (inclus dans CU11)	Destinataire identifié ; émission autorisée.	1. Générer le code du destinataire. 2. L'insérer dans la partition F. 3. Enregistrer le lien copie – destinataire – date.	Échec de marquage : émission annulée et journalisée.
CU08	Responsable sécurité	Copie suspecte ; accès d'audit autorisé.	1. Importer la copie suspecte. 2. Lancer l'analyse. 3. Consulter l'attribution et son niveau de confiance. 4. Journaliser l'enquête.	Résultat ambigu ou copie recadrée : « attribution impossible ou incertaine » ; aucun innocent accusé.
CU09	Administrateur	Session administrateur active.	1. Créer ou modifier un compte, un rôle ou un paramètre. 2. Le système applique et journalise. 3. Il notifie le responsable sécurité de tout changement de privilège.	Tentative d'accès aux images ou d'écriture dans les journaux : refus et alerte.
CU10	Responsable sécurité	Session active.	1. Consulter les alertes. 2. Les filtrer et les qualifier. 3. Ouvrir une enquête si nécessaire.	Aucune modification ni suppression des journaux n'est possible.

3.2 Règles métier

ID	Règle	Fonction concernée	Critère de vérification
RM01	Toute donnée clinique dissimulée est chiffrée ; la dissimulation ne vaut ni chiffrement ni anonymisation.	Stéganographie	Une extraction sans clé ne révèle aucune donnée en clair.
RM02	Le flux recherche retire les identifiants directs de l'en-tête. Un jeton de liaison chiffré peut être conservé dans la RONI si le protocole l'autorise ; seul l'établissement émetteur, détenteur de la clé, peut réidentifier (pseudonymisation).	Export recherche	Sur 20 copies de recherche : aucun identifiant direct exposé ; sans la clé, aucune réidentification ; avec la clé et une autorisation valide, le lien de test est restitué.
RM03	La ROI et ses coordonnées ne sont jamais modifiées par les trois axes ; les écritures sont limitées aux partitions S, W et F de la RONI.	Stéganographie, watermarking, fingerprinting	Comparaison pixel à pixel de la ROI avant et après : zéro différence ; les trois partitions sont disjointes.
RM04	L'original DICOM est conservé sans modification comme référence d'archive.	Import / archivage	Le condensat de l'original est identique avant et après tous les traitements.
RM05	Une image dont la RONI est trop petite pour les partitions S, W et F est déclarée « non marquable » par le système à l'import ; l'utilisateur ne peut pas choisir ce statut. En flux clinique, elle peut être émise en mode dégradé (avertissement, journalisation, alerte), car la disponibilité pour le patient prime. En flux recherche, l'émission est refusée.	Import / émission	Image de test sans capacité suffisante : copie clinique émise avec alerte ; export recherche refusé ; aucune interface ne permet de forcer le statut.

4. Analyse des menaces et des risques

4.1 Méthode d'identification

La méthode retenue associe les cas d'utilisation fonctionnels, les cas d'abus et les cas d'utilisation de sécurité. Chaque cas d'abus menace un ou plusieurs cas d'utilisation (relation « threatens ») ; un ou plusieurs cas d'utilisation de sécurité le mitigent (relation « mitigates ») et sont inclus dans le cas d'utilisation protégé (relation « include »). Ils sont ensuite traduits en exigences de sécurité testables.

Au total : 14 cas d'utilisation, 16 cas d'abus et 15 cas d'utilisation de sécurité, représentés dans quatre diagrammes (annexe B). La classification des menaces WASC v2.0 sert de liste de contrôle pour vérifier qu'aucune classe d'attaque ou de faiblesse n'a été oubliée.

4.2 Hypothèses sur les attaquants

Profil d'attaquant	Motivation / capacité	Accès ou opportunités	Cibles possibles
Utilisateur malveillant (y compris un chercheur destinataire)	Curiosité, fraude, exfiltration ou sabotage ; connaît les fonctions métier ; dispose d'un compte valide.	Dépôt de fichiers, consultation, accès légitime détourné.	Images, données cachées, marques, comptes.
Attaquant externe	Vol de données, perturbation du service, dépôt de contenu malveillant.	API exposées, interface web, fichiers transmis, erreurs de configuration.	API, middleware, comptes, stockage, disponibilité.
Compte compromis	Agir au nom d'un professionnel avec ses privilèges.	Identifiants ou session volés.	Images, métadonnées patient, opérations et traces.
Initié malveillant	Abuser de privilèges élevés (administrateur, opérateur) pour accéder aux données ou effacer des traces.	Fonctions d'administration et d'extraction.	Comptes, journaux, jetons, clés.
Destinataires complices	Diffuser une copie sans être identifiés.	Plusieurs copies légitimes de la même image.	Codes de fingerprinting.

4.3 Catalogue des cas d'abus

Chaque ligne constitue la fiche du cas d'abus : acteur, actif, scénario d'attaque, impact et cas d'utilisation de sécurité qui le mitige.

ID	CU menacé	Acteur malveillant	Actif	Scénario d'attaque	Impact	CUS
CA01	CU01	Attaquant externe	A01	Multiplier les tentatives d'authentification ou exploiter un compte faible.	Usurpation, accès indu.	CUS01
CA02	CU02 à CU06	Utilisateur malveillant, compte compromis	A01–A03	Modifier un identifiant de ressource ou invoquer une opération hors de son rôle.	Divulgation ou modification non autorisée.	CUS02
CA03	CU02	Attaquant externe	A02	Soumettre un DICOM malformé ou un préambule piégé (CVE-2019-11687).	Compromission, fuite, indisponibilité.	CUS03
CA04	CU02	Utilisateur malveillant	A02, A05	Faire afficher un champ d'en-tête piégé comme contenu actif (XSS).	Vol de session.	CUS04
CA05	CU05	Initié malveillant	A03, A04	Détourner l'extraction pour obtenir un lien patient hors de son périmètre.	Réidentification.	CUS05
CA06	CU06	Utilisateur malveillant	A02, A03	Modifier un pixel de la ROI ou ses coordonnées, puis présenter l'image comme intacte.	Altération diagnostique.	CUS06

ID	CU menacé	Acteur malveillant	Actif	Scénario d'attaque	Impact	CUS
CA07	CU06, CU13	Attaquant externe	A03, A04	Fabriquer une preuve sans la clé de l'établissement.	Fausse provenance.	CUS07
CA08	CU07, CU08	Destinataires complices	A03	Comparer ou fusionner deux copies pour neutraliser leurs codes.	Fuite non attribuée ou attribution erronée.	CUS08
CA09	CU04, CU14	Chercheur malveillant	A02, A03	Exploiter des identifiants résiduels ou le jeton pour réidentifier un patient.	Atteinte à la confidentialité.	CUS09
CA10	CU02, CU03	Attaquant externe	A02	Envoyer des fichiers volumineux ou un grand nombre de requêtes.	Déni de service.	CUS10
CA11	CU06, CU08	Utilisateur malveillant	A03	Supprimer, remplacer ou réutiliser une marque issue d'une autre image.	Vérification trompeuse ou attribution impossible.	CUS06, CUS07, CUS08
CA12	CU12, CU13	Utilisateur malveillant	A02, A03	Copier la partition S d'une image du patient Y dans une image du patient X.	Image rattachée au mauvais patient.	CUS11
CA13	CU03, CU04, CU11	Initié malveillant	A02, A03	Cacher ses propres données dans une image qui sort de la plateforme.	Exfiltration de données de santé.	CUS12
CA14	CU09	Initié malveillant (administrateur)	A01, A05	S'attribuer un accès aux images ou effacer des traces.	Accès indu, perte de traçabilité.	CUS13
CA15	CU10, CU08	Initié malveillant	A05	Modifier ou supprimer des entrées de journal, masquer une alerte.	Non-répudiation impossible, incident non détecté.	CUS14
CA16	CU03, CU11	Utilisateur malveillant	A03	Recadrer une image pour la rendre non marquable, puis l'envoyer sans code destinataire.	Fuite non attribuable.	CUS15

Rattachement à la classification WASC:

Cas d'abus	Classes WASC v2.0 correspondantes
CA01	Brute Force ; Insufficient Anti-automation
CA02	Insufficient Authorization ; Predictable Resource Location
CA03	Improper Input Handling
CA04	Cross-Site Scripting ; Improper Output Handling
CA05, CA14	Insufficient Authorization ; Abuse of Functionality
CA06, CA07	Content Spoofing
CA09	Information Leakage
CA10	Denial of Service ; Insufficient Anti-automation
CA11, CA16	Abuse of Functionality ; Insufficient Process Validation
CA12	Insufficient Process Validation
CA13	Abuse of Functionality ; Information Leakage
CA15	Insufficient Authorization ; Improper Filesystem Permissions
CA08	Sans équivalent direct (collusion de destinataires)

4.4 Évaluation et priorisation des risques

Vraisemblance: 1 très faible, 2 faible, 3 possible, 4 probable, 5 très probable.

Impact : 1 négligeable, 2 limité, 3 significatif, 4 majeur, 5 critique.

Score = vraisemblance × impact ;

niveau : 1–4 faible, 5–9 modéré, 10–14 élevé, 15–19 très élevé, 20–25 critique.

Les notes sont des estimations initiales, à réévaluer après les tests.

Risque	V	I	Score / niveau	Traitement décidé
R01 – Fichier DICOM ou préambule piégé (CA03)	4	5	20 – Critique	Valider la structure et le préambule, isoler le traitement, rejeter les fichiers suspects, tester des corpus malformés.
R02 – XSS via l'en-tête DICOM (CA04)	3	5	15 – Très élevé	Traiter les champs comme non fiables, neutraliser l'affichage, surveiller les événements.
R03 – Force brute / compte compromis (CA01)	3	4	12 – Élevé	Authentification forte, limitation des tentatives, verrouillage temporaire et alerte.
R04 – Accès horizontal (CA02)	3	5	15 – Très élevé	Contrôle côté serveur par rôle, établissement, ressource et opération.
R05 – Extraction non autorisée du lien patient (CA05)	3	5	15 – Très élevé	Autorisation au cas par cas, clé réservée à l'établissement, journalisation et alerte.
R06 – Modification de la ROI (CA06)	3	5	15 – Très élevé	ROI immuable, preuve signée, conservation de l'original.
R07 – Fausse marque / fausse provenance (CA07)	3	4	12 – Élevé	Vérifier la signature de l'établissement ; rejeter toute preuve invalide.
R08 – Collusion de deux destinataires (CA08)	3	4	12 – Élevé	Codes anti-collusion ; mesure du taux de détection et des faux positifs.
R09 – Réidentification non autorisée (CA09)	3	5	15 – Très élevé	Nettoyer les identifiants directs, contrôler le protocole, limiter l'accès au jeton.
R10 – Déni de service (CA10)	3	4	12 – Élevé	Limiter taille, débit et concurrence ; surveiller la disponibilité.
R11 – Altération ou rejeu de marque (CA11)	2	4	8 – Modéré	Lier la preuve à la ROI et à l'émission ; journaliser les échecs.
R12 – Échange de jetons entre images (CA12)	2	5	10 – Élevé	La signature couvre la ROI et la partition S.
R13 – Exfiltration par une copie sortante (CA13)	3	5	15 – Très élevé	Régénérer chaque copie sortante ; contenu caché toujours généré par le système.
R14 – Abus de privilèges d'administration (CA14)	2	5	10 – Élevé	Séparation des tâches, authentification forte, journal protégé, notification des changements de privilèges.
R15 – Altération des journaux (CA15)	2	4	8 – Modéré	Journal protégé contre toute modification ; intégrité vérifiée régulièrement.
R16 – Contournement par le mode dégradé (CA16)	3	4	12 – Élevé	Statut décidé par le système ; mode dégradé réservé au flux clinique ; seuil d'alerte.

5. Exigences de sécurité

Chaque exigence cite le cas d'utilisation de sécurité (CUS) dont elle découle et porte un critère de validation mesurable. Les exigences s'appuient sur OWASP ASVS v5.0.0. Les valeurs chiffrées sont des seuils initiaux, à confirmer.

ID	Catégorie	Le système doit…	CUS	Actif / menace	Critère de validation	Prio.
SEC01	**Identification / audit**	attribuer un identifiant unique à chaque compte et associer chaque opération sensible à l'acteur authentifié.	CUS01	A01, A05 ; CA01	Deux comptes de test : identifiants uniques ; chaque événement est attribué au bon compte.	Haute
SEC02	**Authentification**	authentifier fortement tout utilisateur avant l'accès aux images et aux API métier ; verrouiller un compte 15 minutes après 5 échecs consécutifs ; fermer une session après 15 minutes d'inactivité.	CUS01	A01 ; CA01	Requête non authentifiée : refusée. Après 5 échecs : blocage de 15 min. Session inactive : fermée à 15 min.	Haute
SEC03	**Autorisation**	vérifier côté serveur le rôle, l'établissement, le destinataire et le droit sur chaque ressource et chaque opération.	CUS02, CUS05, CUS09	A01–A03 ; CA02, CA05, CA09	Un compte sans droit ne peut ni consulter ni modifier une ressource, même s'il connaît son identifiant.	Haute
SEC04	**Confidentialité**	garantir la confidentialité des échanges entre la PWA et le middleware et celle des données de santé stockées ; ne jamais exposer de clé au frontend.	CUS05, CUS09	A02–A04 ; CA05, CA09	Inspection du trafic, du stockage et des réponses d'API : aucune donnée de santé lisible en clair.	Haute
SEC05	**Intégrité**	conserver l'original de référence et vérifier que la ROI et ses coordonnées sont inchangées.	CUS06	A02, A03 ; CA06, CA11	Toute modification d'un pixel de la ROI ou des coordonnées fait échouer la vérification.	Haute
SEC06	**Authenticité / non-répudiation**	associer la preuve de la ROI à une signature vérifiable de l'établissement émetteur et journaliser chaque émission.	CUS07	A03–A05 ; CA07, CA11	Une preuve signée par l'établissement est acceptée ; une preuve modifiée ou créée sans sa clé est rejetée.	Haute
SEC07	**Audit / détection**	journaliser authentifications, refus, imports, rejets, traitements, extractions et exports ; détecter les séquences anormales et alerter le responsable sécurité.	CUS01, CUS03, CUS04, CUS05, CUS09, CUS14	A05 ; CA01, CA03–CA05, CA09, CA15	Chaque événement provoqué est journalisé avec horodatage et acteur ; une séquence anormale produit une alerte ; aucun contenu médical ni secret dans les journaux.	Haute
SEC08	**Disponibilité / résilience**	rejeter tout fichier de plus de 500 Mo, limiter à 10 traitements DICOM simultanés et à 20 requêtes par minute et par compte pour les opérations sensibles.	CUS03, CUS10	A02 ; CA03, CA10	Fichier > 500 Mo rejeté ; 11e traitement simultané mis en attente ; dépassement de débit limité ; opérations normales maintenues.	Haute
SEC09	**Intégrité des journaux**	garantir qu'aucune entrée de journal ne peut être modifiée ou supprimée sans que l'atteinte soit détectée, y compris par l'administrateur ; vérifier l'intégrité des journaux chaque jour.	CUS13, CUS14	A05 ; CA14, CA15	Modifier ou supprimer une entrée de test : l'atteinte est détectée et une alerte est émise.	Haute
SEC10	**Séparation des tâches**	interdire à l'administrateur l'accès aux images et l'écriture dans les journaux, interdire au responsable sécurité la gestion des rôles, et notifier au responsable sécurité tout changement de privilège.	CUS13	A01, A05 ; CA14	Compte administrateur : accès à une image et suppression d'une entrée de journal refusés ; un changement de rôle produit une notification.	Haute

5.1 Exigences spécifiques aux services de dissimulation

La justification de l'axe stéganographie figure dans le cahier des charges.

ID	Service	CUS	Risque	Le système doit…	Validation
SEC-D01	**Stéganographie**	CUS05, CUS09	Lecture ou fuite du jeton caché.	chiffrer le jeton de liaison patient avant de le dissimuler dans la partition S ; sans la clé de l'établissement émetteur, aucune donnée identifiante n'est restituée.	20 copies de recherche : extraction sans clé, aucune identité ; extraction autorisée, seul le lien prévu est restitué.
SEC-D02	**Contrôle DICOM entrant**	CUS03, CUS04	Préambule, en-tête ou contenu piégé.	contrôler la structure, le préambule, les champs et le contenu de tout fichier entrant avant analyse, affichage ou traitement ; aucune valeur n'est interprétée comme contenu actif.	Fichiers malformés, préambule exécutable et en-têtes contenant des chaînes XSS : rejet ou affichage neutralisé, alerte et journalisation.
SEC-D03	**Watermarking**	CUS06, CUS07, CUS11	Altération de la ROI, fausse provenance, échange de jetons.	cacher dans la partition W une preuve signée par l'établissement, couvrant le condensat de la ROI, ses coordonnées, le contenu de la partition S et l'identifiant de l'émetteur ; la ROI n'est jamais modifiée.	Pixel de la ROI, coordonnées ou partition S modifiés, signature absente ou invalide, jetons échangés entre deux images : 100 % des cas rejetés.
SEC-D04	**Fingerprinting**	CUS08	Fuite de copie et collusion de deux destinataires.	insérer un code propre au destinataire à chaque émission et permettre l'analyse d'une copie suspecte ; objectif : reconnaître au moins un des deux complices après fusion de deux copies, sans accuser d'innocent.	100 essais contrôlés de fusion de deux copies : au moins un complice identifié, aucun innocent accusé ; résultat probabiliste documenté.
SEC-D05	**Gestion des clés**	CUS05, CUS07	Vol de clé, falsification des marques.	conserver les clés hors des fichiers DICOM, des journaux et du frontend ; utiliser une clé de jeton distincte de la clé de signature ; réserver et journaliser l'accès aux services autorisés.	Inspection des fichiers, API et journaux : aucune clé en clair ; appels non autorisés refusés ; deux clés distinctes.
SEC-D06	**Nettoyage avant export**	CUS09	Identifiants directs résiduels.	retirer ou neutraliser les identifiants directs de l'en-tête et des métadonnées avant tout export recherche ; le jeton n'est conservé que si le protocole l'autorise.	20 exports de test : aucun identifiant direct ; jeton éventuel inaccessible sans la clé.
SEC-D07	**Copies sortantes**	CUS12	Exfiltration par des données cachées.	reconstruire toute copie sortante à partir de l'original archivé et des seules marques du système ; le contenu caché est toujours généré par le système, jamais fourni par l'utilisateur.	Soumettre une image contenant des données cachées ajoutées : la copie émise est identique, bit à bit, à l'original augmenté des seules marques attendues.
SEC-D08	**Mode dégradé**	CUS15	Contournement du marquage.	déterminer lui-même le statut « non marquable » à l'import ; limiter le mode dégradé au flux clinique vers un destinataire autorisé ; avertir, journaliser et alerter ; au-delà de 3 émissions dégradées par un utilisateur en 24 heures, déclencher une alerte d'enquête.	Image non marquable : émission clinique avec alerte, export recherche refusé ; statut impossible à forcer ; la 4e émission dégradée en 24 h déclenche l'alerte d'enquête.

5.2 Exigences liées aux fichiers et aux API

Le système doit accepter uniquement les profils DICOM pris en charge ; contrôler la structure, l'en-tête et le préambule ; appliquer la taille maximale et les limites de débit de SEC08 ; valider côté serveur les paramètres et identifiants de ressources ; vérifier les droits à chaque appel ; retourner des erreurs génériques sans donnée médicale, chemin interne ni secret ; journaliser les rejets sans contenu médical ni secret.

6. Justification de l'approche d'ingénierie des exigences de sécurité (IES/SRE)

6.1 Approche retenue : cas d'abus et cas d'utilisation de sécurité

L'approche retenue combine les cas d'abus et les cas d'utilisation de sécurité, deux extensions des cas d'utilisation. Les cas d'utilisation fonctionnels décrivent les services attendus. Chaque cas d'abus décrit le comportement d'un acteur malveillant et menace un cas d'utilisation (« threatens »). Un cas d'utilisation de sécurité est dérivé de chaque cas d'abus, le mitige (« mitigates ») et est inclus dans le cas d'utilisation protégé (« include »). Il est spécifié par ses préconditions, ses postconditions, un scénario normal et un scénario d'attaque, sans imposer de mécanisme technique.

6.2 Justification comparative

Comparés aux autres approches d'IES, les cas d'utilisation offrent un support élevé à l'élicitation des exigences et obtiennent le meilleur score pour retrouver les exigences de sécurité omises. Ils définissent une prévention des conflits entre exigences, prennent mieux en compte les exigences non fonctionnelles que les autres approches, et restent faciles à comprendre et à modifier pour une équipe débutante.

Pourquoi pas les autres approches :

- **SQUARE** : méthode en neuf étapes, lourde, adaptée surtout aux grands projets.
- **OCTAVE** : ses concepts sont difficiles à comprendre et à mettre en œuvre, et la méthode vise surtout l'évaluation des risques d'une organisation.
- **Récits d'abus** : ils ne supportent pas les exigences non fonctionnelles ; leur formulation sert seulement à rédiger les scénarios d'attaque.

6.3 Mise en œuvre dans le projet

Étape	Activité	Méthode / outil	Résultat
1. Cas d'utilisation	Décrire les rôles et les parcours ; un acteur par rôle.	Atelier ; diagrammes UML (annexe A).	CU01 à CU14.
2. Cas d'abus	Pour chaque CU, identifier au moins un acteur malveillant, un actif, un scénario et un impact.	Brainstorming ; relation « threatens » ; classification WASC en contrôle.	CA01 à CA16 ; chaque CU est couvert.
3. Cas d'utilisation de sécurité	Dériver au moins un CUS par cas d'abus.	Relations « mitigates » et « include ».	CUS01 à CUS15 ; quatre diagrammes (annexe B) ; fiches (annexe C).
4. Exigences	Traduire chaque CUS en exigence testable.	OWASP ASVS v5.0.0 comme référentiel.	SEC01–SEC10, SEC-D01–SEC-D08, SEC-R01–SEC-R04.
5. Priorisation	Évaluer vraisemblance et impact de chaque cas d'abus.	Score = vraisemblance × impact.	R01 à R16.
6. Validation	Associer un critère mesurable à chaque exigence.	Critères SMART ; plan de tests en phase de tests.	Critères définis pour toutes les exigences.

7. Disponibilité et résilience

ID	Exigence	Critère de validation
SEC-R01	Le service reste utilisable pour les opérations autorisées et signale proprement toute indisponibilité.	Disponibilité mensuelle ≥ 99 % en environnement de démonstration (objectif initial).
SEC-R02	Les dépôts, contrôles et traitements ne bloquent pas l'interface.	95 % des requêtes API ordinaires traitées en moins de 2 s, hors transfert et traitement d'image (objectif initial).
SEC-R03	Les originaux DICOM et les preuves associées peuvent être restaurés après incident.	Restauration d'un échantillon démontrée avant livraison.
SEC-R04	Les erreurs, rejets, échecs de traitement et événements de sécurité déclenchent des alertes.	Une hausse anormale simulée des erreurs ou des rejets produit une alerte.

Les moyens de surveillance, de sauvegarde et de reprise seront choisis lors de la phase de déploiement.

8. Validation et traçabilité des exigences

Chaque exigence de sécurité porte son critère de validation, et chaque règle métier le sien. Le plan de tests détaillé (scénarios, jeux de données, outils) sera établi lors de la phase de tests ; chaque test reprendra l'identifiant de son exigence (par exemple T-SEC01 pour SEC01).

Chaque exigence (BF, SEC, SEC-D, SEC-R) a un identifiant stable. Elle est suivie par une issue reliée à sa menace source. La matrice suivante relie chaque cas d'abus à la chaîne complète.

CU	Cas d'abus	CUS	Exigences
CU01	CA01	CUS01	SEC01, SEC02, SEC07
CU02 à CU06	CA02	CUS02	SEC03
CU02	CA03	CUS03	SEC-D02, SEC07, SEC08
CU02	CA04	CUS04	SEC-D02, SEC07
CU05	CA05	CUS05	SEC-D01, SEC-D05, SEC03, SEC04, SEC07
CU06	CA06	CUS06	SEC05, SEC-D03
CU06, CU13	CA07	CUS07	SEC06, SEC-D03, SEC-D05
CU07, CU08	CA08	CUS08	SEC-D04
CU04, CU14	CA09	CUS09	SEC-D06, SEC-D01, SEC03, SEC04, SEC07
CU02, CU03	CA10	CUS10	SEC08, SEC-R01 à SEC-R04
CU06, CU08	CA11	CUS06, CUS07, CUS08	SEC05, SEC06, SEC-D03, SEC-D04
CU12, CU13	CA12	CUS11	SEC-D03
CU03, CU04, CU11	CA13	CUS12	SEC-D07
CU09	CA14	CUS13	SEC10, SEC09
CU10, CU08	CA15	CUS14	SEC09, SEC07
CU03, CU11	CA16	CUS15	SEC-D08

9. Hypothèses, risques résiduels et points ouverts

- **Hypothèses** : seuls les échanges DICOM sans perte sont couverts ; les valeurs chiffrées des exigences sont des seuils initiaux.

- **Risques résiduels** : un recadrage limité à la ROI, fait par un destinataire après réception, efface le fingerprint; le contournement volontaire avant émission est, lui, encadré par RM05 et SEC-D08. La résistance à la collusion porte sur deux destinataires et reste probabiliste.
- **Points ouverts** : seuils à valider (taille, débit, disponibilité, session, mode dégradé) ; RPO/RTO (Recovery Point Objective/Recovery Time Objective) et politique de conservation ; capacité réelle de la RONI.

10. Références

1. MedImage Trust, Cahier des charges, version du 8 novembre 2026 (contexte, solution, architecture, standards et références techniques).
2. G. Sindre, A. L. Opdahl, « Eliciting security requirements with misuse cases », Requirements Engineering, vol. 10, n° 1, 2005.
3. D. G. Firesmith, « Security Use Cases », Journal of Object Technology, vol. 2, n° 3, 2003.
4. N. R. Mead, E. D. Hough, T. R. Stehney, « Security Quality Requirements Engineering (SQUARE) Methodology », rapport CMU/SEI-2005-TR-009, 2005.
5. OWASP, Application Security Verification Standard (ASVS) v5.0.0, mai 2025.
6. Web Application Security Consortium, WASC Threat Classification v2.0.
7. M. Picado Ortiz (Cylera Labs), démonstration de fichiers PE/DICOM, avril 2019 ; vulnérabilité CVE-2019-11687 (préambule du format DICOM Part 10).

Annexe A — Diagrammes de cas d’utilisation fonctionnels

Les diagrammes d’activité (parcours d’une image) figurent en annexe A du cahier des charges.

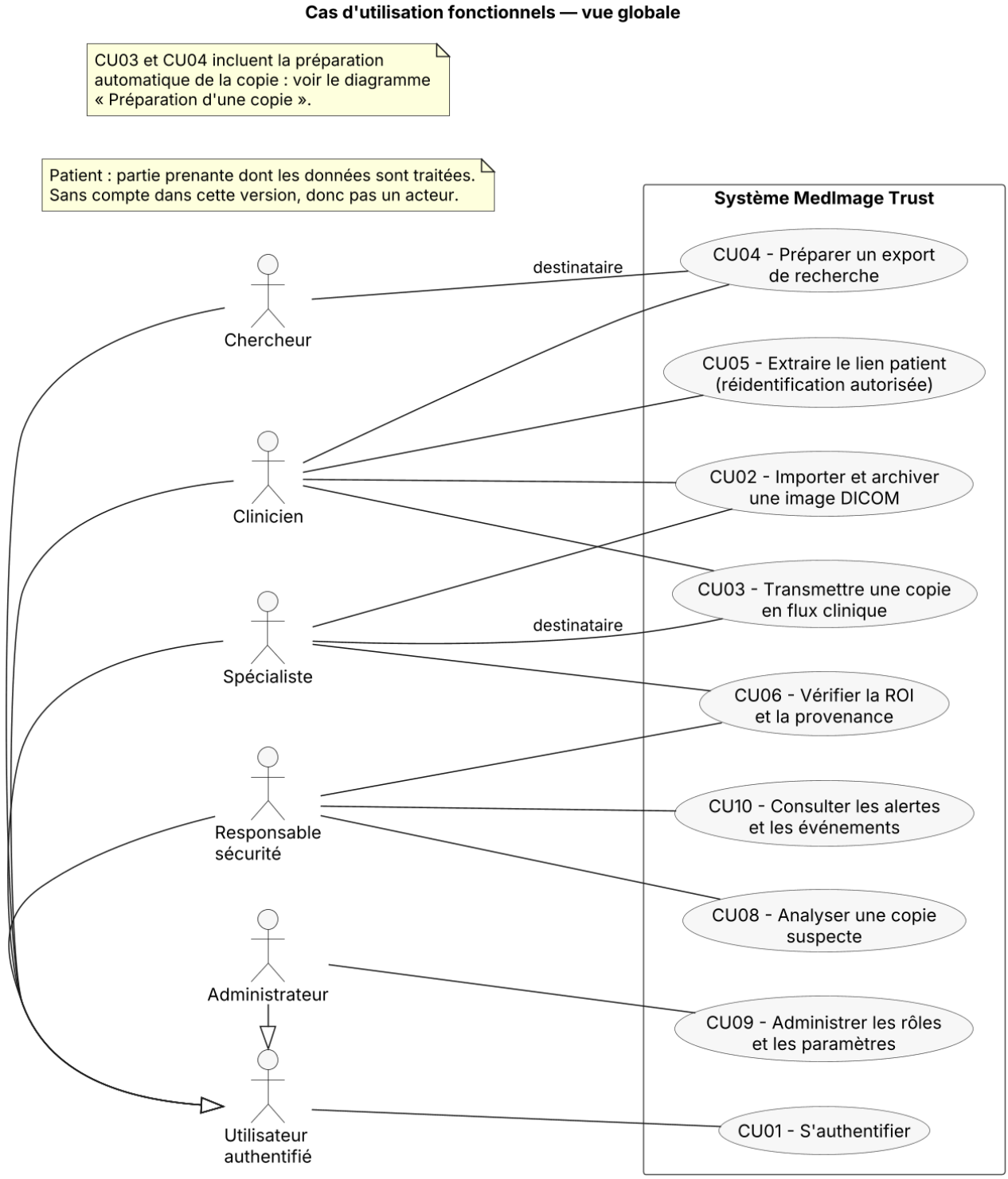


Figure A1 — Cas d’utilisation fonctionnels : vue globale

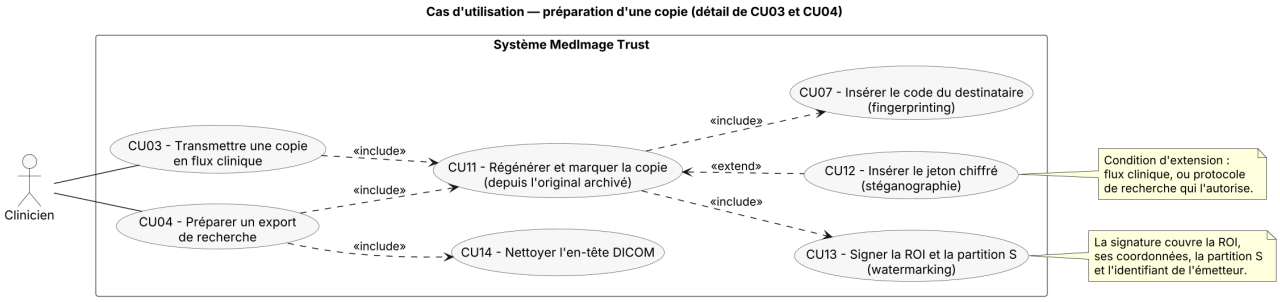


Figure A2 — Préparation d'une copie (détail de CU03 et CU04)

Annexe B — Cas d’abus et cas d’utilisation de sécurité

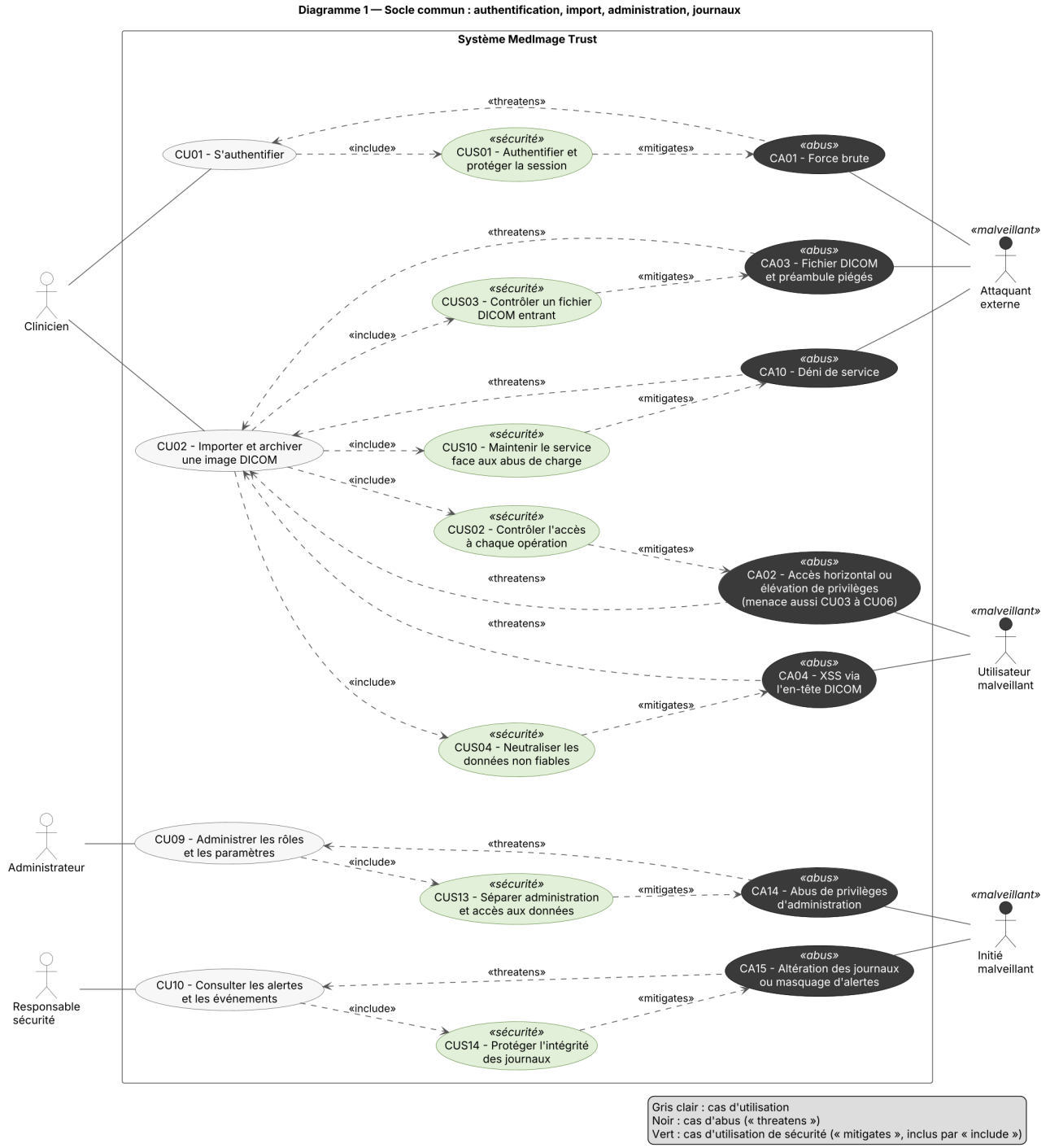


Figure B1 — Socle commun : authentification, import, administration, journaux

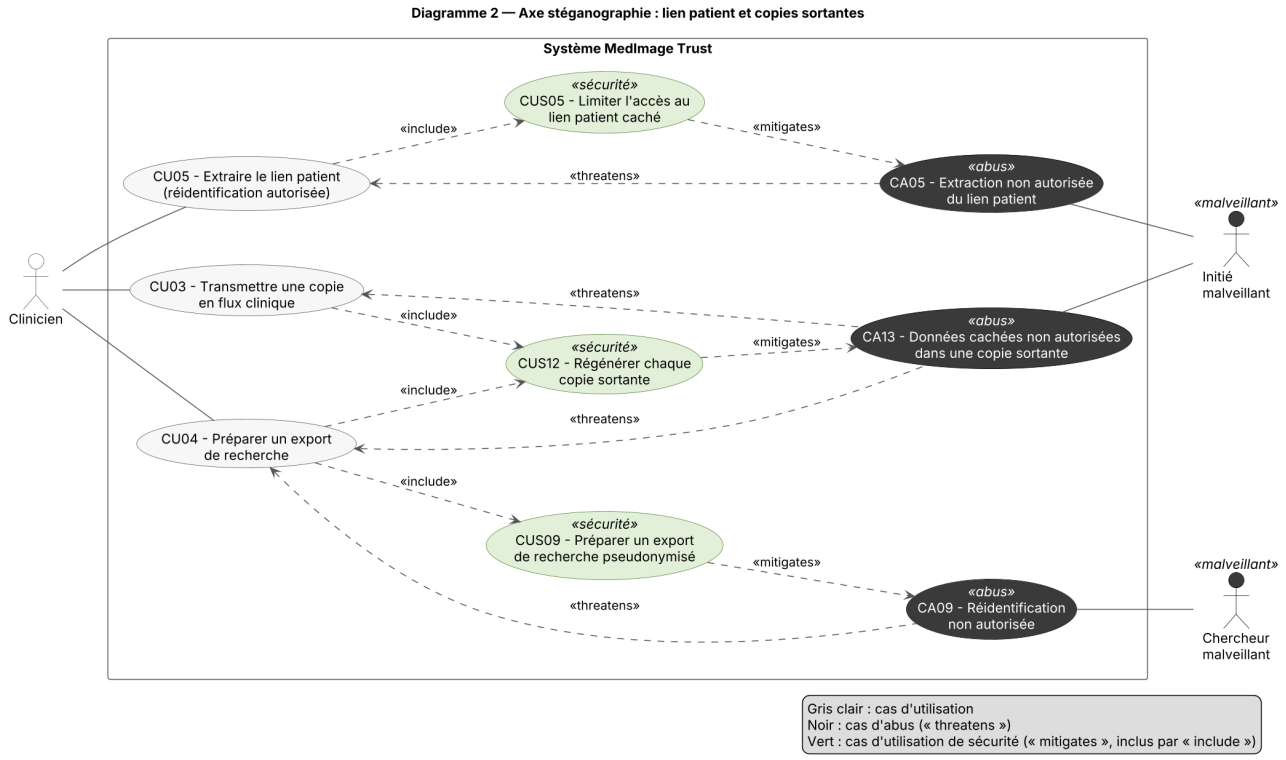


Figure B2 — Axe stéganographie

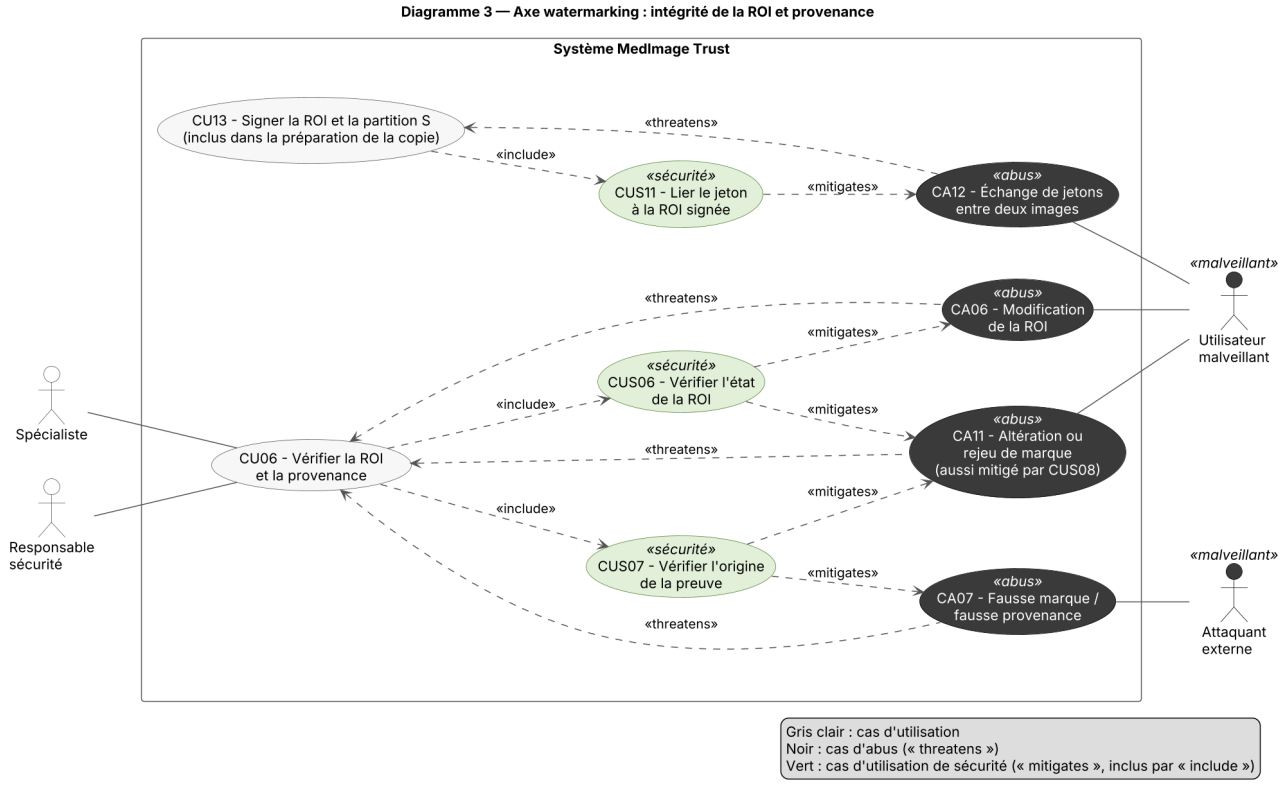
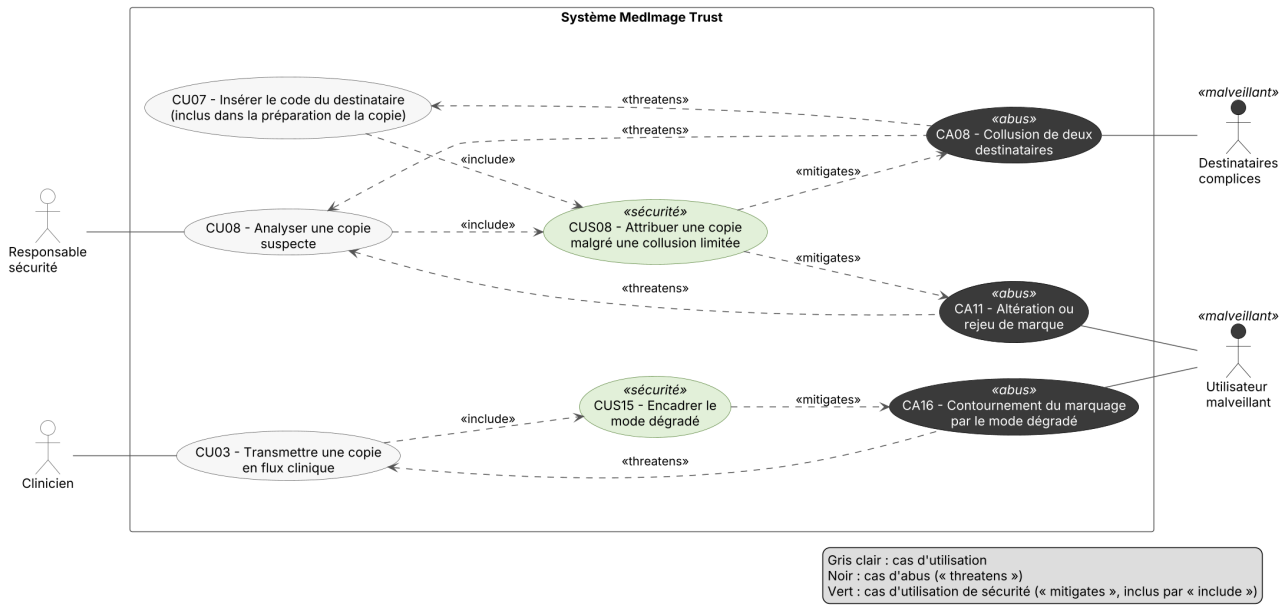


Figure B3 — Axe watermarking

Diagramme 4 — Axe fingerprinting : attribution des fuites



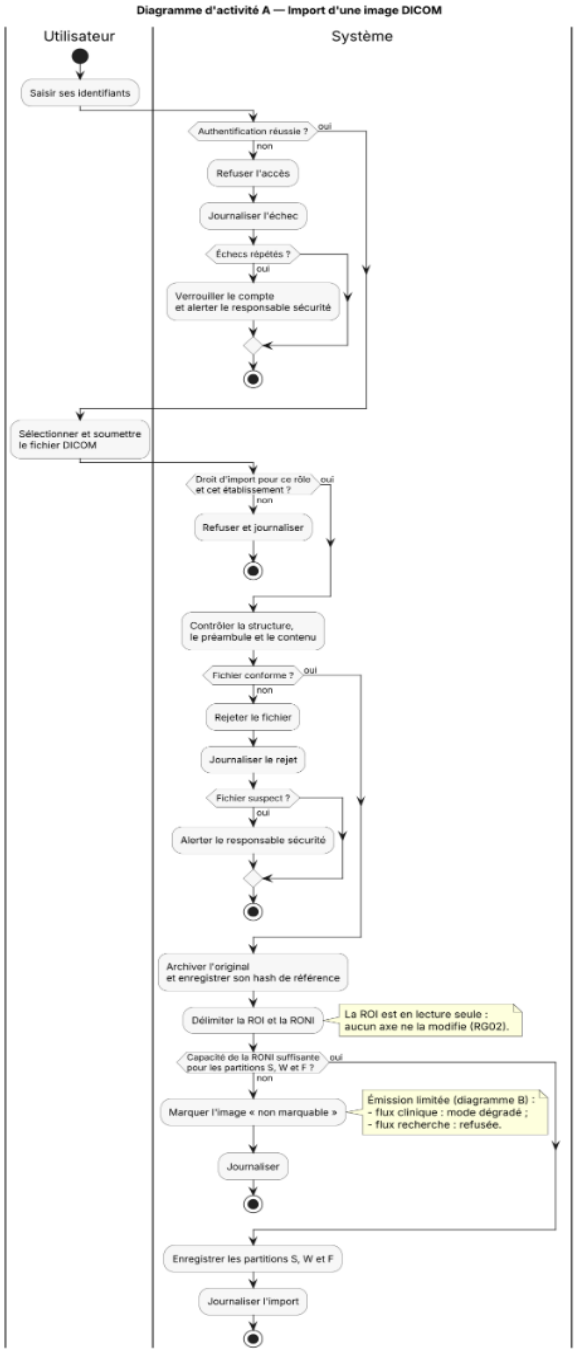


Figure — diagramme d'activité

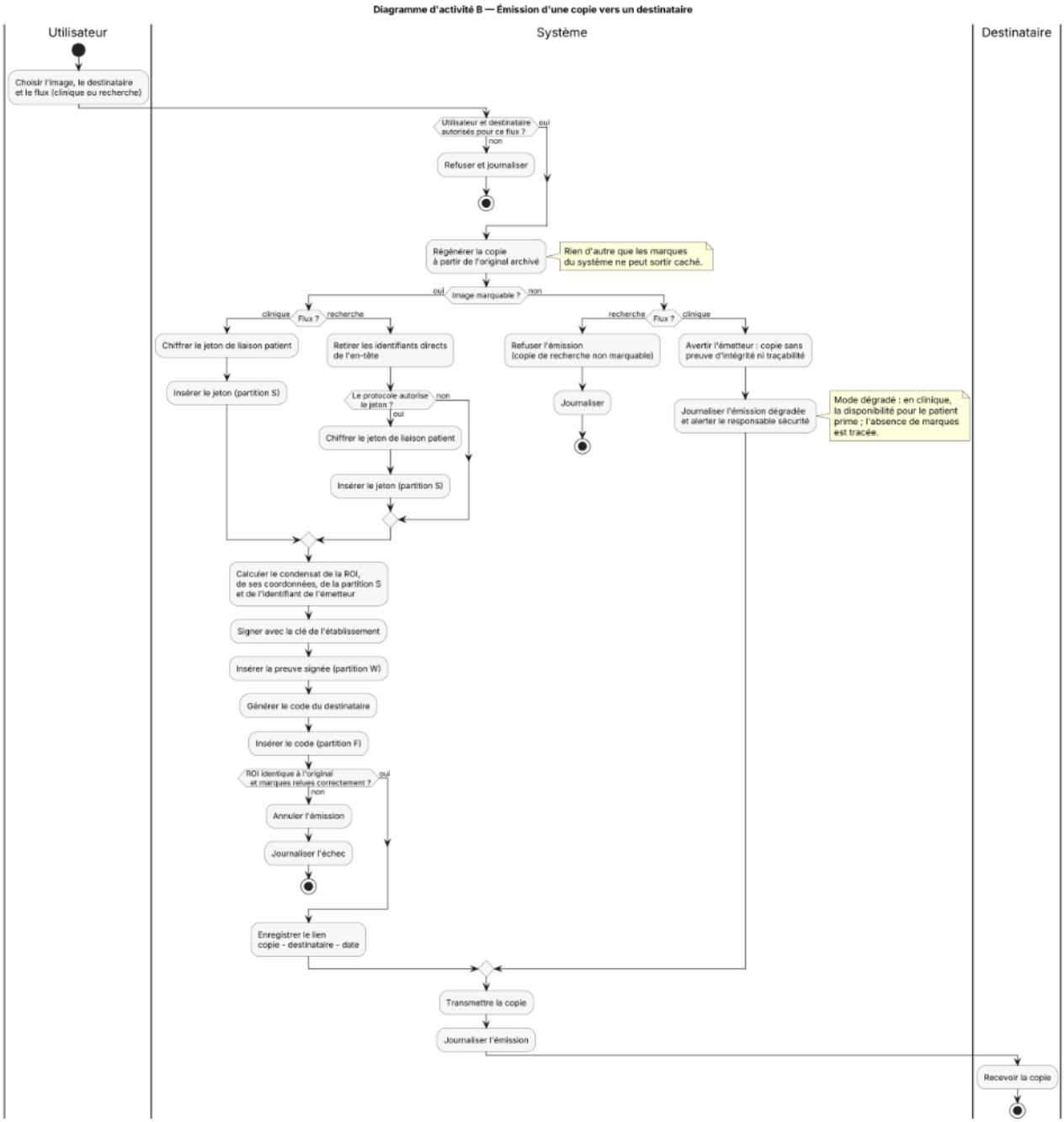


Figure — diagramme d'activité

Annexe C — Fiches des cas d’utilisation de sécurité

Les fiches décrivent les interactions et les résultats attendus, sans imposer de mécanisme technique.

CUS01 — Authentifier et protéger la session

Cas d’abus mitigé	CA01
Préconditions	Compte existant ; acteur identifié.
Scénario normal	L’acteur demande l’accès à une fonction protégée ; le système vérifie que l’accès est légitime et ouvre une session limitée à son rôle.
Scénario d’attaque	L’attaquant multiplie les tentatives ou réutilise une session compromise ; l’accès est refusé et l’événement est signalé.
Postconditions	Session valide limitée au rôle, ou refus sans divulgation.

CUS02 — Contrôler l’accès à chaque opération

Cas d’abus mitigé	CA02
Préconditions	Session active ; ressource et opération identifiées.
Scénario normal	L’acteur demande une ressource ; le système vérifie les droits liés à son rôle et à son périmètre.
Scénario d’attaque	L’acteur tente d’accéder à une ressource d’un autre établissement ou destinataire ; la demande échoue.
Postconditions	Aucune donnée hors périmètre n’est retournée.

CUS03 — Contrôler un fichier DICOM entrant

Cas d’abus mitigé	CA03
Préconditions	Fichier soumis.
Scénario normal	Le système examine la conformité du fichier avant de le confier aux traitements métier.
Scénario d’attaque	Le fichier présente une structure, un préambule ou un contenu suspect ; le traitement est interrompu et une alerte est créée.
Postconditions	Seuls les fichiers acceptés poursuivent le parcours.

CUS04 — Neutraliser les données non fiables

Cas d’abus mitigé	CA04
Préconditions	En-tête et métadonnées considérés comme non fiables.
Scénario normal	Le système présente les valeurs utiles sans les interpréter comme des instructions.
Scénario d’attaque	Une valeur contient un contenu actif ; elle est neutralisée et ne déclenche aucune action dans l’interface.
Postconditions	Aucun contenu actif ne s’exécute.

CUS05 — Limiter l'accès au lien patient caché

Cas d'abus mitigé	CA05
Préconditions	Jeton chiffré présent ; demande d'extraction soumise.
Scénario normal	Le système vérifie que l'acteur est habilité à obtenir le lien dans le cadre prévu.
Scénario d'attaque	Une demande non autorisée ou sans clé tente l'extraction ; aucune donnée identifiante n'est restituée et l'événement est signalé.
Postconditions	Le lien n'est restitué qu'à un acteur habilité.

CUS06 — Vérifier l'état de la ROI

Cas d'abus mitigé	CA06, CA11
Préconditions	Image et preuve disponibles.
Scénario normal	Le système vérifie que la ROI et ses coordonnées correspondent à l'état prouvé.
Scénario d'attaque	Un pixel, les coordonnées ou la preuve ont été modifiés ou remplacés ; la vérification échoue.
Postconditions	Une ROI intacte est reconnue ; toute altération entraîne un échec.

CUS07 — Vérifier l'origine de la preuve

Cas d'abus mitigé	CA07, CA11
Préconditions	Preuve disponible ; émetteur déclaré.
Scénario normal	Le système vérifie que la preuve provient bien de l'établissement émetteur.
Scénario d'attaque	Une preuve falsifiée ou produite sans la clé de l'établissement est présentée ; elle est rejetée.
Postconditions	L'origine n'est reconnue qu'après une vérification réussie.

CUS08 — Attribuer une copie malgré une collusion limitée

Cas d'abus mitigé	CA08, CA11
Préconditions	Copie suspecte et registre des émissions disponibles.
Scénario normal	Le responsable sécurité demande l'analyse d'une copie et obtient une attribution avec son niveau de confiance.
Scénario d'attaque	Deux destinataires fusionnent leurs copies, ou une marque est altérée ; le système tente l'attribution et signale ses limites sans accuser d'innocent.
Postconditions	Rapport d'attribution, ou résultat explicitement indéterminé.

CUS09 — Préparer un export de recherche pseudonymisé

Cas d'abus mitigé	CA09
Préconditions	Protocole et destinataire autorisés.
Scénario normal	Le système prépare une copie sans identifiant direct ; le jeton chiffré n'est conservé que si le protocole l'autorise.
Scénario d'attaque	Une donnée directe subsiste ou un export non autorisé est demandé ; l'export est bloqué.
Postconditions	Copie sans identifiant direct ; jeton inaccessible sans la clé.

CUS10 — Maintenir le service face aux abus de charge

Cas d'abus mitigé	CA10
Préconditions	Service disponible ; limites définies.
Scénario normal	Le système traite les demandes dans les limites de taille, de débit et de concurrence.
Scénario d'attaque	Un volume anormal ou un fichier hors limite est soumis ; la demande est rejetée ou différée sans bloquer les demandes normales.
Postconditions	Service disponible pour les opérations légitimes.

CUS11 — Lier le jeton à la ROI signée

Cas d'abus mitigé	CA12
Préconditions	Copie en préparation ; partition S remplie ou vide.
Scénario normal	Le système prouve ensemble la ROI, ses coordonnées, la partition S et l'émetteur, sous la signature de l'établissement.
Scénario d'attaque	La partition S d'une autre image est copiée ; la vérification échoue car la preuve ne correspond plus.
Postconditions	Jeton et ROI sont indissociables.

CUS12 — Régénérer chaque copie sortante

Cas d'abus mitigé	CA13
Préconditions	Original archivé ; émission autorisée.
Scénario normal	Chaque copie est reconstruite à partir de l'original et des seules marques du système.
Scénario d'attaque	Un utilisateur tente d'envoyer une image contenant ses propres données cachées ; la copie émise n'en contient aucune.
Postconditions	Rien d'autre que les marques du système ne sort caché.

CUS13 — Séparer administration et accès aux données

Cas d'abus mitigé	CA14
Préconditions	Rôles définis.
Scénario normal	L'administrateur gère comptes et rôles sans accès aux images ni écriture dans les journaux ; tout changement de privilège est notifié.
Scénario d'attaque	L'administrateur s'attribue un rôle clinique ou tente d'effacer une trace ; la demande est refusée ou signalée au responsable sécurité.
Postconditions	Aucun acteur ne cumule administration et audit.

CUS14 — Protéger l'intégrité des journaux

Cas d'abus mitigé	CA15
Préconditions	Journal actif.
Scénario normal	Chaque événement est ajouté sans possibilité de modification ; l'intégrité du journal est vérifiable.
Scénario d'attaque	Une entrée est modifiée ou supprimée ; la vérification détecte la rupture et alerte.
Postconditions	Journal complet et vérifiable.

CUS15 — Encadrer le mode dégradé

Cas d’abus mitigé	CA16
Préconditions	Image déclarée non marquable par le système à l’import.
Scénario normal	En flux clinique, la copie est émise avec avertissement, journalisation et alerte.
Scénario d’attaque	Un utilisateur recadre volontairement des images ou multiplie les émissions dégradées ; le statut ne peut pas être forcé et les envois répétés déclenchent une enquête.
Postconditions	Toute copie non marquée est tracée et limitée au flux clinique.